Using SPDM Authorization for PLDM Firmware Updates: Authorization Policy and Measurement Manifest Capabilities

Brett Henning, Broadcom, SPDM Co-chair
Patrick Caporale, Lenovo, PMCI Co-chair
Scott Phuong, Microsoft

Copyright © 2026 DMTF

DMTF – An Industry Standards Organization

WHO Led by innovative, industry-leading companies, DMTF has a global presence with members from around the world.

WHAT DMTF standards support diverse emerging and traditional IT infrastructures including cloud, virtualization, network, servers and storage. A complete list is available at **www.dmtf.org/standards.**

WHY Nationally and internationally recognized by ANSI and ISO, DMTF standards enable a **more integrated and cost-effective approach to management through interoperable solutions.**

HOW Simultaneous development of Open Source and Open Standards is made possible by DMTF, which has the support, tools and infrastructure for efficient development and collaboration.

Why Standards?

Vendors and Developers

- Creates a common framework for innovation
- Develops an ecosystem of interoperability that increases customer awareness and drives market adoption
- Reduces development and integration costs as well as production costs for standards-based components

Customers

- Achieve interoperability and portability
- Choose products based on feature innovation
- Standards-based best-practice solutions, where all vendors bring ideas to the table
- Reduced costs through increased adoption and expansion of the ecosystem

DMTF Alliance Partnership

DMTF and its Alliance Partners develop a common dialogue and work together for the good of the industry, avoiding overlap and helping ensure interoperability



PLDM REFERENCE MANIFEST

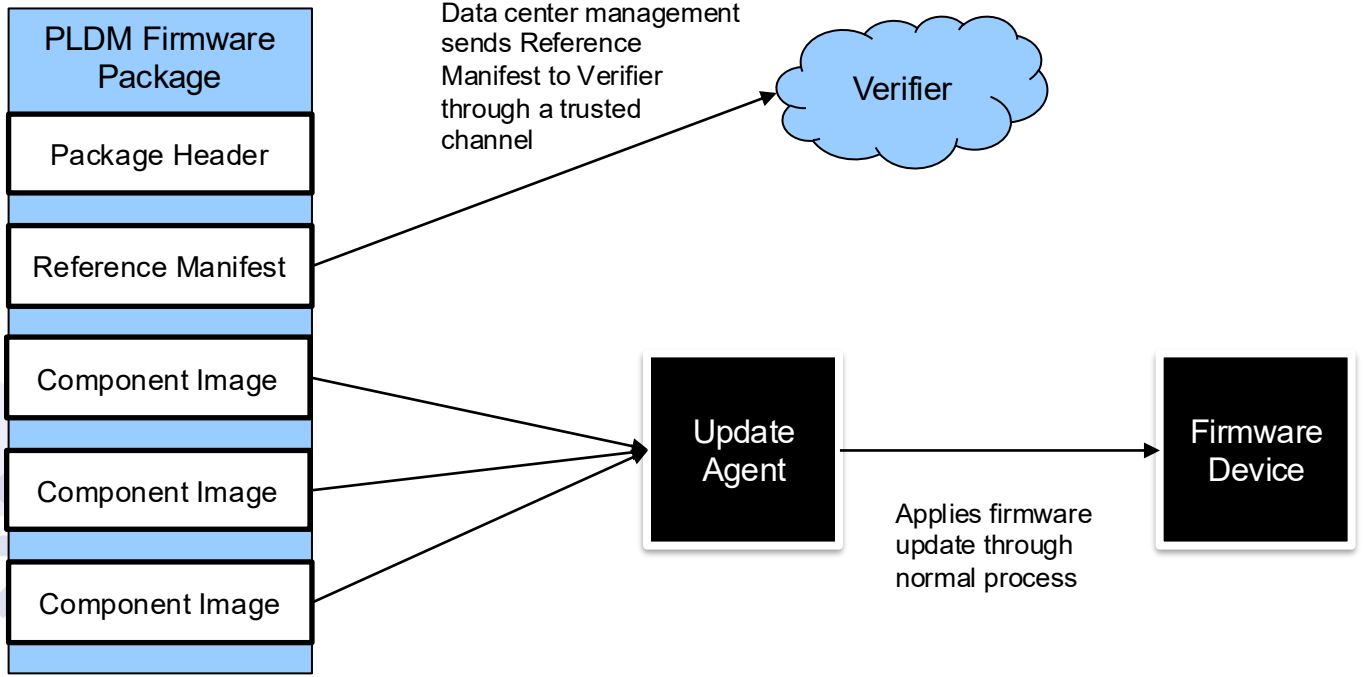
The Measurement Problem

- SPDM has a MEASUREMENTS command that returns measurements of critical elements from a device
  - How does a verifier know what a measurement value should be?
  - A reference measurement manifest contains the known good measurements
  - The IETF/TCG Concise Reference Integrity Manifest (CoRIM) is one format for a reference manifest
  - Reference manifests are signed and cannot be updated dynamically
- The problem: How should the reference manifest be delivered to a production system?

Reference Manifest in PLDM FW Updates

- PLDM for Firmware Update version 1.3 adds reference manifest support
  - The PLDM standard does not define the contents of the reference manifest
  - Different formats are available from different standards bodies
  - The PLDM standard puts an identifying tag on the reference manifest so the definition can be discovered
- The data center management system is responsible for delivering the reference manifest to the verifier
  - The verifier can be a server, a BMC, or any policy enforcement engine

PLDM Measurement Manifest



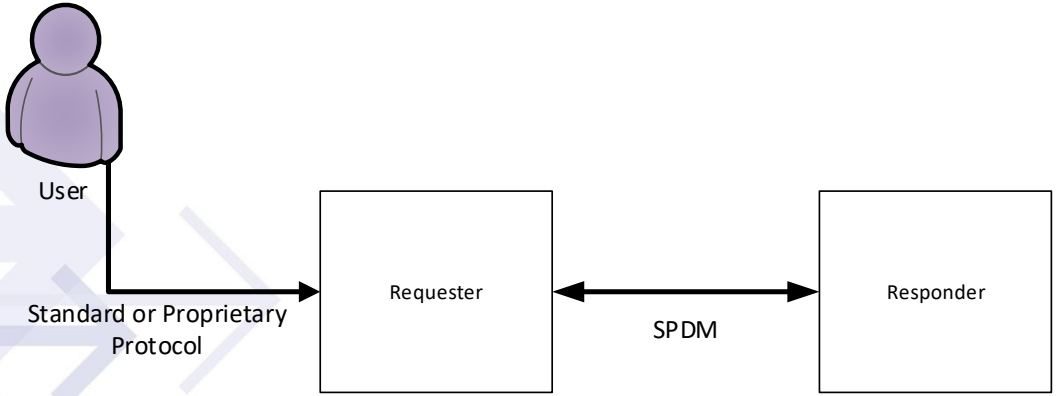
Implementation Considerations

- The PLDM FW Update spec does not provide guidance on which reference manifest format to use
  - Choose whichever format works for your ecosystem
- There can be multiple manifests in a firmware package
  - Reference manifests are typically signed
  - There can be one reference manifest per firmware device ID
  - Downstream devices also support manifests

DMTF AUTHORIZATION POLICY

SPDM Authorization Refresher

- 2 Use Cases – the User is the authorized actor
  - SPDM Requester represents user
  - SPDM Requester is a proxy for user



Authorization Policy Goals

- The SPDM Authorization Spec (DSP0289) defines the authorization protocol
  - DSP0294 defines the policy configuration for SPDM and PMCI protocols
- Prioritize the most sensitive commands
  - Commands that change the SPDM configuration
  - PLDM firmware update commands
  - Additional commands may be added in the future

Authorization Policy Details

Privilege Setting	Defining Spec
Get Key Pair Info	DSP 274 (SPDM)
Set Key Pair Info	DSP 274 (SPDM)
Certificate and Slot	DSP 274 (SPDM)
Firmware Update	DSP 267 (PLDM FW Update)
Update Security Revision	DSP 267 (PLDM FW Update)
Reset to Default	DSP 289 (SPDM Authorization)

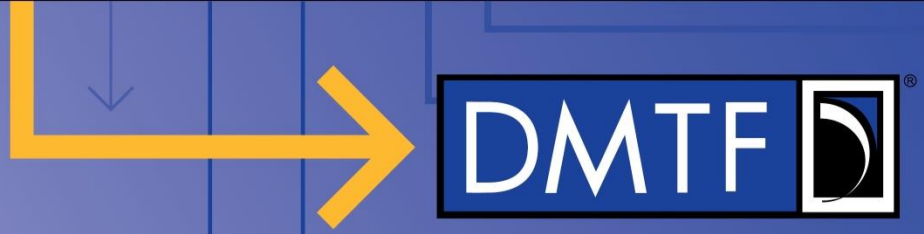
- A system owner could assign different users the privileges to
  - User 1: Manage keys and certificates
  - User 2: Manage the loaded firmware plus reset to default

Authorization Next Steps

- Implement support for the DMTF Authorization Policy
- Provide feedback to DMTF on additional features in the Authorization Policy
  - Members can provide feedback in the SPDM Github repo
  - Non-members can use the feedback portal - https://www.dmtf.org/standards/feedback
- Vendors and other standards bodies can create their own authorization policies
  - Authorization supports multiple policies at the same time – others should define policies for their solution space

Next Steps

- Join a DMTF Work Group and bring enhancements
- Follow the DMTF Standards site:
  - https://www.dmtf.org/standards/pmci
  - https://www.dmtf.org/standards/spdm
- Use the Feedback Portal to submit requests
  - https://www.dmtf.org/standards/feedback



For more information,
visit dmtf.org

Learn about membership at
dmtf.org/join

Thank you!